

Plantilla de Excel para Cálculo de IGM y ROI

Este documento describe la estructura sugerida de una hoja de cálculo para implementar el **Índice de Gestión de Debilidades (IGM)** y aproximaciones de **ROI** asociadas a iniciativas de mejora en CWE.

1. Estructura general del libro de Excel

Se recomiendan, al menos, tres hojas:

1. **Datos_Encuesta**
Contiene las respuestas codificadas de cada organización.
2. **Calculo_IGM**
Implementa la fórmula de cálculo del IGM a partir de las respuestas.
3. **Calculo_ROI**
Introduce datos económicos y calcula indicadores de retorno de la inversión.

Datos_Encuesta
Contiene las respuestas codificadas de cada organización.

Calculo_IGM
Implementa la fórmula de cálculo del IGM a partir de las respuestas.

Calculo_ROI
Introduce datos económicos y calcula indicadores de retorno de la inversión.

2. Hoja Datos_Encuesta

Columnas sugeridas (por fila, una organización):

- ID_Org – Identificador anónimo de la organización.
- Sector – Código de sector (ej. SALUD, ENERGIA, AP, etc.).
- Tamano – Categoría de tamaño (ej. 1, 2, 3...).
- CWE_Taxonomia – Respuesta codificada a 2.1 (ej. 0–3 según nivel).
- Politica_Debilidades – Respuesta a 2.2.
- Estrategia_Integrada – Respuesta a 2.3.
- Identif_Sistematico – Indicador derivado de 3.1.
- Mapeo_CWE – Respuesta a 3.2.
- Metrics_CWE – Respuesta a 3.3.
- Integracion_CWE_CVE_CVSS – Respuesta a 3.4.
- Uso_Top25 – Respuesta a 4.2.
- Uso_KEV – Respuesta a 4.3.
- Uso_MIHw – Respuesta a 4.4.
- Metrics_Prevalencia – Respuesta a 5.1.
- Objetivos_Reducccion – Respuesta a 5.2.
- Tiempos_Remediacion – Respuesta a 5.3.
- Tendencias_Temporales – Respuesta a 5.4.
- Benchmark_Externo – Respuesta a 5.5.
- SDLC_Integrado – Respuesta a 6.1.
- Guias_Alineadas_CWE – Respuesta a 6.2.
- Herramientas_Map_CWE – Respuesta a 6.3.
- Lista_CWE_Prioritarios – Respuesta a 6.4.
- Riesgos_CWE – Respuesta a 7.1.
- Cumplimiento_Map_CWE – Respuesta a 7.2.
- Reporte_Direccion_CWE – Respuesta a 7.3.
- Formacion_CWE – Respuesta a 8.1.
- Cultura_CWE – Respuesta a 8.2.
- Promocion_Listas – Respuesta a 8.3.
- Repo_Vuln_CWE – Respuesta a 9.1.
- Integraciones_Datos – Respuesta a 9.2.
- Calidad_Datos – Respuesta a 9.3.
- Modelo_Costes – Respuesta a 10.1.
- ROI_Iniciativas – Respuesta a 10.2.
- Tendencia_Inversion – Respuesta a 10.3.
- Percepcion_Impacto – Respuesta a 10.4.

Cada respuesta debe codificarse previamente a valores numéricos (0–4, 1–5, etc.) según un diccionario de codificación acordado.

3. Hoja Calculo_IGM

3.1. Ponderaciones sugeridas

Incluir una tabla con pesos, por ejemplo:

- $w_{CWE_Taxonomia} = 0,08$
- $w_{Politica_Debilidades} = 0,06$
- $w_{Estrategia_Integrada} = 0,06$
- $w_{Mapeo_CWE} = 0,08$
- $w_{Metricas_CWE} = 0,08$
- $w_{Integracion_CWE_CVE_CVSS} = 0,06$
- $w_{Uso_Top25} = 0,06$
- $w_{Uso_KEV} = 0,04$
- $w_{Metricas_Prevalencia} = 0,06$
- $w_{Objetivos_Reduccion} = 0,06$
- $w_{Tiempos_Remediacion} = 0,06$
- $w_{Tendencias_Temporales} = 0,04$
- $w_{SDLC_Integrado} = 0,07$
- $w_{Riesgos_CWE} = 0,05$
- $w_{Cumplimiento_Map_CWE} = 0,06$
- $w_{Reporte_Direccion_CWE} = 0,04$
- $w_{Formacion_CWE} = 0,04$
- $w_{Repo_Vuln_CWE} = 0,04$

Ajustar para que la suma de pesos sea 1 (100 %).

3.2. Normalización de respuestas

Si, por ejemplo, una pregunta está codificada en escala 0–4, la normalización puede ser:

$$\text{Valor_Normalizado} = \text{Valor_Codificado} / 4$$

Crear columnas auxiliares en Calculo_IGM que tomen los valores de Datos_Encuesta, los normalicen y apliquen los pesos.

3.3. Fórmula del IGM por organización

En una fila de Calculo_IGM, por ejemplo:

$$\text{IGM} = (\text{CWE_Taxonomia_norm} * w_{CWE_Taxonomia}) + (\text{Politica_Debilidades_norm} * w_{Politica_Debilidades}) + \dots$$

Finalmente, escalar:

$$\text{IGM}_{100} = \text{IGM} * 100$$

De este modo, cada organización obtiene un valor entre 0 y 100, donde 0 indica ausencia total de gestión estructurada de debilidades y 100 un nivel muy alto de madurez (ideal teórico).

4. Hoja Calculo_ROI

La hoja de ROI no pretende ser un modelo actuarial completo, pero puede incluir:

- Coste_Anual_Incidentes – Estimación del coste total anual de incidentes de seguridad relacionados con debilidades (antes de una iniciativa).
- Coste_Anual_Incidentes_Posterior – Estimación posterior a la iniciativa.
- Inversion_Iniciativa – Coste de la iniciativa de mejora (formación, herramientas, procesos).
- Ahorro_Anual = Coste_Anual_Incidentes – Coste_Anual_Incidentes_Posterior.
- $ROI = (Ahorro_Anual - Inversion_Iniciativa) / Inversion_Iniciativa$.

Opcionalmente, se puede introducir:

- IGM_Antes y IGM_Después para analizar la relación entre la mejora del índice y el ROI obtenido.

Esta tabla puede alimentarse con datos reales cuando existan o con estimaciones informadas, y usarse como base para escenarios “qué pasaría si” (por ejemplo, aumentar el IGM en 10 puntos y estimar la reducción en incidentes).

5. Visualizaciones sugeridas

En el propio Excel pueden incluirse gráficos:

- Histograma de distribución de IGM por sector.
- Gráfico de dispersión IGM vs. coste anual de incidentes.
- Gráfico de barras comparando IGM medio por tamaño de organización.

Todo ello ayuda a convertir los números en mensajes comprensibles incluso para quienes no disfrutaban especialmente de las hojas de cálculo.

6. Comentarios finales

La plantilla propuesta es deliberadamente modular. Permite desde un uso básico (IGM con pocas preguntas) hasta modelos más sofisticados (ponderaciones refinadas, análisis sectoriales, correlaciones con datos económicos). Lo importante es mantener la trazabilidad entre las respuestas de la encuesta y los cálculos, de manera que cualquier número pueda explicarse siempre con la misma serenidad con la que se explica un CWE bien mapeado a su CVE.